Design and apply context-aware access controls based on user identity, device posture, location, and application risk

List of teammates–

S.no	Name	college	Mail-id
1	Thanusuya S R	Shree Venkateshwara arts and science college	thanusuyaraju2006@gmail.com
2	Mythra L	Shree Venkateshwara arts and science college	mythral2023cs@gmail.com
3	Renukadevi M	Shree Venkateshwara arts and science college	renukadevim2023cs@gmail.com
4	Sarmila S	Shree Venkateshwara arts and science college	Sarmilas2023cs@gmail.com

Design and Apply Context-Aware Access Controls Based on User Identity

Overview :-

In today's rapidly evolving digital environment, traditional network-centric security models are no longer sufficient to safeguard organizational resources. Conventional VPN-based access solutions often grant broad network-level permissions, assuming trust based on a user's location or connection to the internal network. This implicit trust significantly increases the attack surface, allowing attackers to move laterally within the network once they gain initial access. To address these security gaps, organizations are increasingly adopting Zero Trust security frameworks, where trust is never implicit, and access is granted only after rigorous verification of identity and context. This project focuses on implementing context-aware access controls based on user identity, ensuring that access decisions are made dynamically based on multiple factors, including user credentials, device posture, location, application risk, and behavior. By evaluating these contextual elements in real time, the system can enforce precise access policies that grant users the minimum privileges necessary to perform their tasks while preventing unauthorized access to sensitive applications and data.

The core of this project involves deploying Zscaler Private Access (ZPA), a clouddelivered, identity-aware solution that establishes secure, application-specific connectivity without exposing the network to the internet. Unlike traditional VPNs, which place users on the internal network and often allow unrestricted lateral movement, ZPA uses a service-initiated model to create one-to-one connections between authorized users and the applications they are permitted to access. This approach ensures that corporate resources, IP addresses, and internal systems remain invisible to unauthorized users, effectively mitigating threats such as port scanning, distributed denial-of-service (DDoS) attacks, and lateral movement by malicious actors. By decoupling application access from network access, ZPA allows organizations to implement least-privilege access policies, meaning users and devices are granted only the permissions necessary for their role, significantly reducing the potential attack surface.

Furthermore, implementing context-aware access control improves visibility and monitoring capabilities, enabling administrators to track user activity, detect anomalies, and respond to security incidents more efficiently. It also simplifies the user experience by eliminating the complexities associated with traditional VPN solutions, reducing operational overhead, and supporting a modern, distributed workforce. Remote employees, third-party vendors, and contractors can securely access applications without exposing the network or requiring complex configurations, while security teams gain granular control over access policies and can enforce adaptive authentication

measures. Ultimately, this project establishes a robust and scalable foundation for secure access management, ensuring that organizational resources are protected against modern cyber threats while enabling efficient and seamless user access in alignment with Zero Trust principles.

Introduction

In modern digital environments, organizations rely heavily on networked systems, cloud platforms, and remote access to perform daily operations. Traditional access control mechanisms mainly depend on static credentials such as usernames, passwords, or fixed network permissions. However, these conventional methods are no longer sufficient to protect sensitive data and resources from evolving cyber threats. Attackers can exploit stolen credentials, compromised devices, or unauthorized network access to infiltrate systems.

To address these challenges, **context-aware access control** has emerged as an advanced security approach that evaluates multiple contextual factors before granting access to resources. Instead of relying only on login credentials, context-aware systems consider parameters such as **user identity, device type, location, time of access, network status, and behavioral patterns**. By analyzing these contextual elements, the system can dynamically adjust access permissions and enforce stronger security policies.

User identity plays a crucial role in this approach. Identity-based access control ensures that only authorized users can access specific resources based on their roles, responsibilities, and verified identity attributes. When combined with contextual information, this method enables organizations to implement more intelligent and adaptive security mechanisms. For example, a user may be granted full access when logging in from a trusted device within the organization's network, but the same user might face additional authentication or restricted permissions when accessing the system from an unknown device or remote location.

The objective of this project is to **design and implement a context-aware access control system that makes access decisions based on verified user identity and environmental context**. The proposed system will monitor contextual parameters and apply predefined policies to ensure that access to network resources is granted only under appropriate conditions. This approach improves security, reduces unauthorized access risks, and enhances overall network protection.

By implementing context-aware identity-based access control, organizations can move towards a **Zero Trust security model**, where every access request is continuously verified and evaluated before allowing interaction with critical resources.

Abstract

With the rapid growth of digital systems, cloud computing, and remote access technologies, ensuring secure access to network resources has become a major challenge for organizations. Traditional access control mechanisms mainly rely on static authentication methods such as usernames and passwords. These methods are often insufficient to prevent unauthorized access because attackers can exploit stolen credentials or compromised devices. Therefore, more intelligent and adaptive security solutions are required to protect sensitive data and systems.

This project focuses on the **design and implementation of a context-aware access control system based on user identity**. Context-aware access control enhances traditional security models by evaluating additional contextual factors such as user identity, location, device type, time of access, and network conditions before granting access to resources. By considering these contextual parameters, the system can dynamically adjust permissions and enforce security policies in real time.

The proposed system verifies the identity of users and analyzes their contextual information to determine whether access should be granted, restricted, or denied. For example, users accessing the system from trusted devices within the organization's network may receive full access, while access attempts from unfamiliar devices or unusual locations may require additional authentication or be blocked. This adaptive approach helps reduce security risks and prevents unauthorized entry into the network.

The implementation of context-aware identity-based access control improves the overall security of network environments by enabling smarter decision-making and continuous verification of access requests. This approach also aligns with modern security frameworks such as the **Zero Trust model**, where every access attempt is evaluated before permission is granted. As a result, the proposed system enhances protection, ensures better management of user access, and strengthens network security in modern computing environments.

Use Case Scenario

Scenario 1: Finance Team Accessing the ERP System

A senior accountant from the finance department needs to log in to the company's **Enterprise Resource Planning (ERP)** system to complete the monthly payroll process. The employee connects remotely using an official company laptop. When the user opens the **ZPA Client Connector**, authentication is performed through **Azure Active Directory** along with **multi-factor authentication (MFA)**.

ZPA then checks several security conditions including the user's identity, membership in the **Finance_ERP_Users** group, device security status (such as active antivirus

and enabled disk encryption), and the connection environment. After verifying that all requirements are satisfied, the policy engine allows access and creates a secure micro-tunnel directly to the ERP application.

The user can perform payroll operations within the ERP system but cannot view or access other internal company resources such as development servers or the HR database.

Output:

- User identity verified and authorization granted based on group membership
- Secure micro-tunnel created only for ERP application access
- Other internal systems and network segments remain hidden and inaccessible

Scenario 2: Contractor Access to a Project Repository

A temporary software consultant has been hired for a three-month project and requires access only to a specific **Git repository** located on an internal server. The contractor is added to the company's identity management system as a guest user and placed in the **Project_X_Contractors** group.

When the contractor connects through the **ZPA client**, the platform verifies the user's identity and checks the device's security compliance, including operating system patch level and firewall status. ZPA policies allow access exclusively to the Git repository using **SSH (port 22)** or **HTTPS (port 443)**, and only during official working hours between **9 AM and 5 PM**.

The contractor is able to clone repositories, push updates, and pull code changes but cannot locate or connect to any other internal company systems such as the corporate intranet or file storage servers.

Output:

- Access limited by time and user role
- Contractor permitted to use only the Git repository application
- Movement to other internal systems completely restricted

Scenario 3: Executive Access to Confidential Financial Documents

A company vice president needs to review confidential **merger and acquisition (M&A)** documents stored within a corporate **SharePoint** site. The executive is traveling abroad and connects from a hotel business center using a company-issued tablet.

After opening the **ZPA Client Connector**, the executive authenticates through **Azure Active Directory with MFA**. ZPA evaluates the user's identity, verifies their

executive-level group membership, and checks the device posture, which is compliant. However, the login originates from an unusual international location and the target application contains highly sensitive information.

Because of this elevated risk score, the policy engine allows access but applies additional security controls. The user is given **read-only access**, and functions such as downloading or printing documents are disabled. The session is also monitored for suspicious activity like bulk downloads. Additionally, a security alert is sent to the organization's security team.

Output:

- User authenticated with MFA and compliant device but flagged due to unusual location
- Access allowed in read-only mode with restrictions on download and printing •

  Security team notified for monitoring potential risks

Scenario 4: IT Support Technician Access to Internal Support Tools

An IT support specialist needs access to the organization's **ServiceNow platform** and a **remote desktop jump host** in order to assist an employee with a technical issue. The technician connects from their home office using a company-managed desktop computer.

Once the **ZPA Client Connector** is launched, the technician authenticates using **Azure Active Directory with MFA**. ZPA evaluates the user's identity, verifies their membership in the **IT_Support** group, checks the device security posture, and confirms that the home office network is approved for IT staff.

Since all security conditions meet the organization's trust requirements, the policy engine establishes secure micro-tunnels to both ServiceNow and the remote desktop support system. The technician can complete support tasks effectively but still cannot access unrelated systems such as financial databases, HR records, or software source code repositories.

Output:

- User successfully authenticated and authorized in a trusted environment
- Secure micro-tunnels created for ServiceNow and remote desktop jump host
- Least-privilege access enforced with other systems remaining inaccessible

Scenario 5: Accessing a High-Risk Application from a Public Network

A marketing coordinator needs to update a campaign in the company's **Salesforce CRM** system. The employee connects from a coffee shop using a companymanaged smartphone.

After launching the **ZPA Client Connector**, authentication occurs via **Azure Active Directory with MFA**. ZPA verifies the user's identity and confirms membership in the **Marketing_Salesforce_Users** group. The device is compliant and properly managed; however, the connection is made through **public Wi-Fi**, which is considered a high-risk network.

Although the user and device are trusted, the unsafe network environment could expose sensitive customer data. Instead of denying access completely, the policy routes the session through a **secure browser isolation service**. This means the Salesforce interface runs inside a protected temporary container, preventing any sensitive information from being stored on the device or intercepted through the public network.

Output:

- User authenticated and device verified but network classified as high risk
- Access provided through browser isolation for enhanced security
- Session runs in a protected container with restrictions on copy, paste, and downloads

Stage – 1

Title:

Design and Apply Context-Aware Access Controls Based on User Identity

In today's rapidly evolving digital environment, traditional network-centric security models are no longer sufficient to safeguard organizational resources. Conventional VPN-based access solutions often grant broad network-level permissions, assuming trust based on a user's location or connection to the internal network. This implicit trust significantly increases the attack surface, allowing attackers to move laterally within the network once they gain initial access. To address these security gaps, organizations are increasingly adopting **Zero Trust security frameworks**, where trust is never implicit, and access is granted only after rigorous verification of identity and context. This project focuses on implementing **context-aware access controls based on user identity**, ensuring that access decisions are made dynamically based on multiple factors, including user credentials, device posture, location,

application risk, and behavior. By evaluating these contextual elements in real time, the system can enforce precise access policies that grant users the minimum privileges necessary to perform their tasks while preventing unauthorized access to sensitive applications and data.

The core of this project involves deploying **Zscaler Private Access (ZPA)**, a cloud-delivered, identityaware solution that establishes secure, application-specific connectivity without exposing the network to the internet. Unlike traditional VPNs, which place users on the internal network and often allow unrestricted lateral movement, ZPA uses a **service-initiated model** to create one-to-one connections between authorized users and the applications they are permitted to access. This approach ensures that corporate resources, IP addresses, and internal systems remain invisible to unauthorized users, effectively mitigating threats such as port scanning, distributed denial-of-service (DDoS) attacks, and lateral movement by malicious actors. By decoupling application access from network access, ZPA allows organizations to implement **least-privilege access policies**, meaning users and devices are granted only the permissions necessary for their role, significantly reducing the potential attack surface.

Furthermore, implementing context-aware access control improves visibility and monitoring capabilities, enabling administrators to track user activity, detect anomalies, and respond to security incidents more efficiently. It also simplifies the user experience by eliminating the complexities associated with traditional VPN solutions, reducing operational overhead, and supporting a modern, distributed workforce. Remote employees, third-party vendors, and contractors can securely access applications without exposing the network or requiring complex configurations, while security teams gain granular control over access policies and can enforce adaptive authentication measures. Ultimately, this project establishes a robust and scalable foundation for secure access management, ensuring that organizational resources are protected against modern cyber threats while enabling efficient and seamless user access in alignment with Zero Trust principles.

List of Vulnerability Table

S.no	Vulnerability	CWE/CVE - No
1	Cross-site scripting (stored)	**79**
2	Broken Access Control	**285**
3	SQL Injection	**89**
4	Broken Authentication	**285**
5	Insecure Direct Object Reference	**639**

6	Security Misconfiguration	**732**
7	Cross-Site Request Forgery	**352**
8	Cleartext Transmission of Sensitive Information	**319**
9	ClickJacking	**1021**
10	webserver allows password autocompletion	**310**

REPORT:-

1)

Vulnerability Name:- Cross site scripting (stored)

CWE/CVE : -79

OWASP/SANS Category:- A03:2021 -Injections

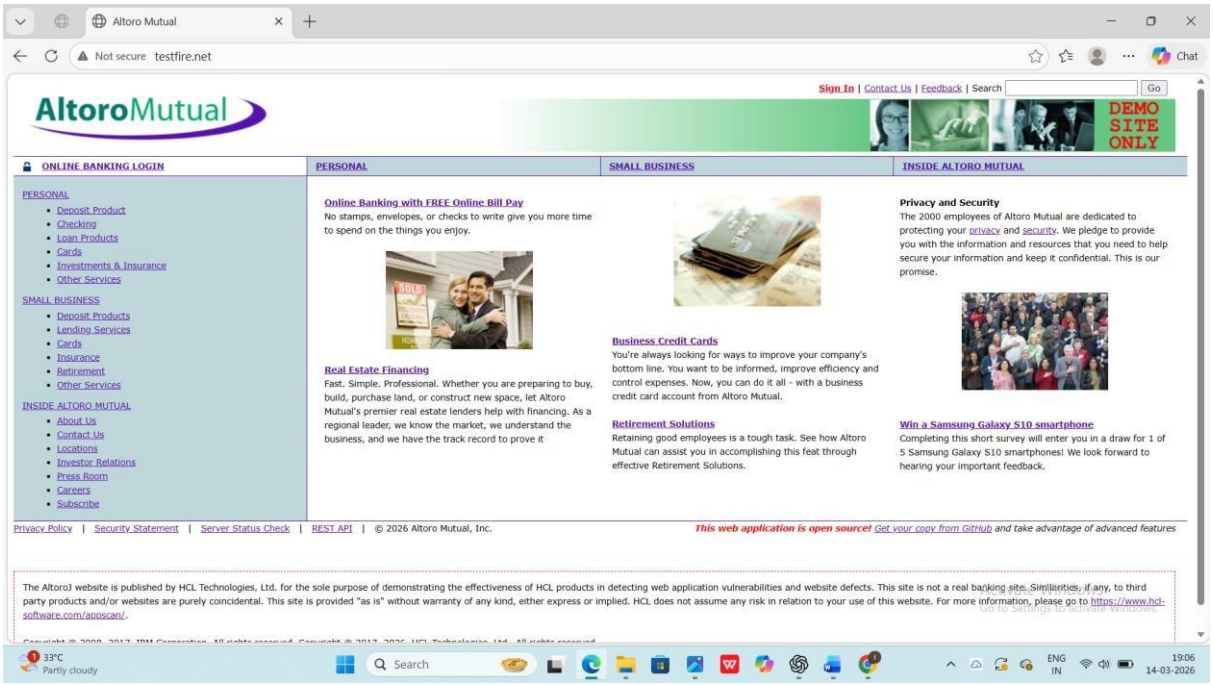
Description:- It occurs when a malicious script is injected directly into a vulnerable web application. Reflected XSS involves the reflection of a malicious script of a web application, onto a user's browser..

Business Impact : The application stores dangerous data in a database, message forum, visitor log, or other trusted data store. Later, the dangerous data is subsequently read back into the application and included in dynamic content. From an attacker's perspective, the optimal place to inject malicious content is in an area that is displayed to either many users or particularly interesting users. Interesting users typically have elevated privileges in the application or interact with sensitive data that is valuable to the attacker. If one of these users executes malicious content, the attacker may be able to perform privileged operations on behalf of the user or gain access to sensitive data belonging to the user. Vulnerability path: http://testfire.net

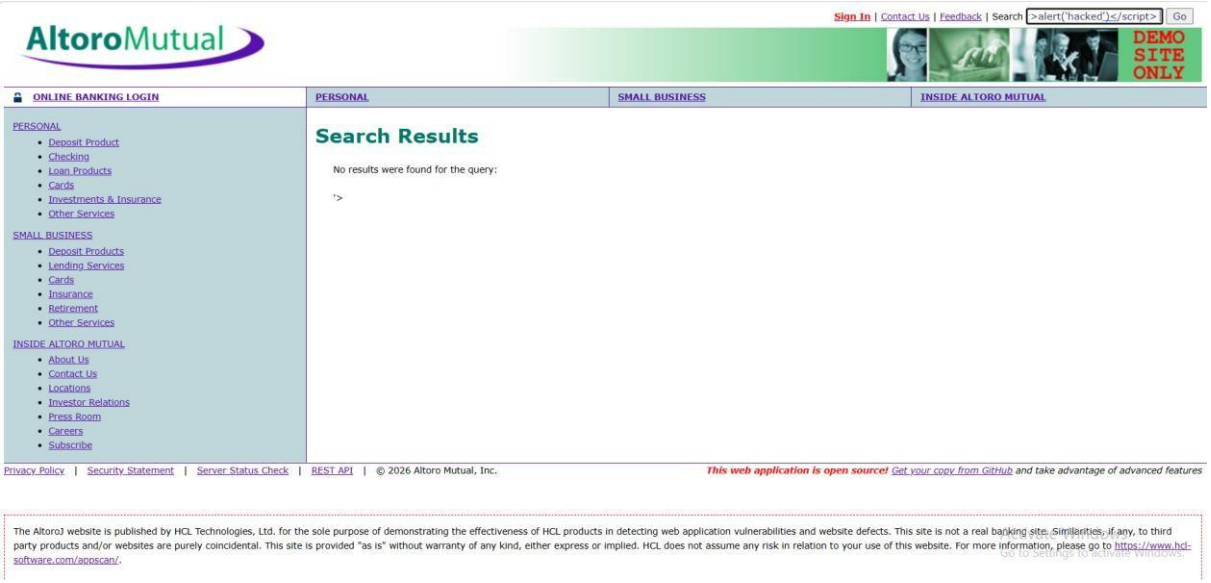
Vulnerability parameter:

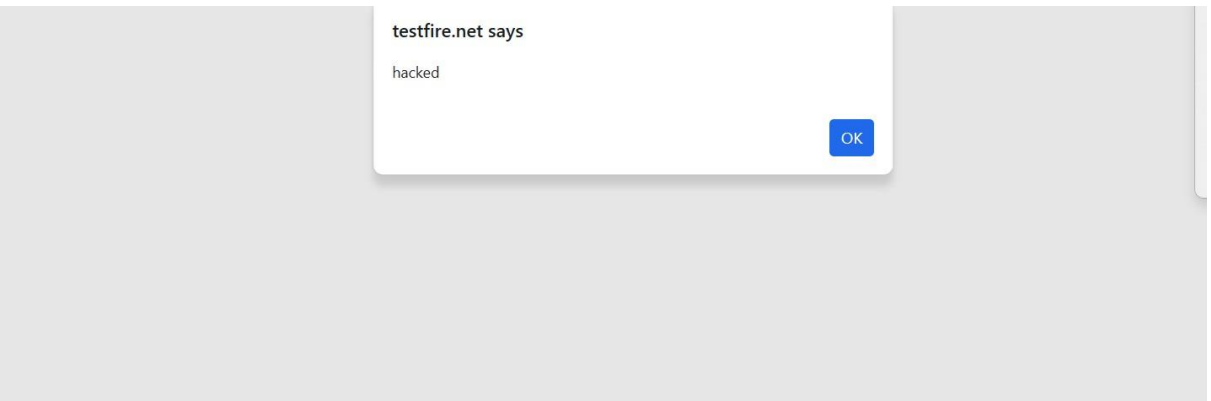
http://testfire.net/search.jsp?query=%27%3E%3Cscript%3Ealert%28%27hacked%27%29%3 C%2Fscrip t%3E

Steps to Reproduce: ➢ Access the URL



In the search box we will input some code to perform the vulnerability.





Recommendation: • When interacting with databases, use parameterized statements or prepared statements to avoid SQL injection, which can be a vector for XSS. • Sanitize and validate all user inputs and ensure that any data displayed on the web page is properly encoded. Use output encoding libraries or functions to prevent script injection.

2)

Vulnerability Name:- Active Debug Code

Vulnerability Name:- SQL injection

CWE/CVE : - 89

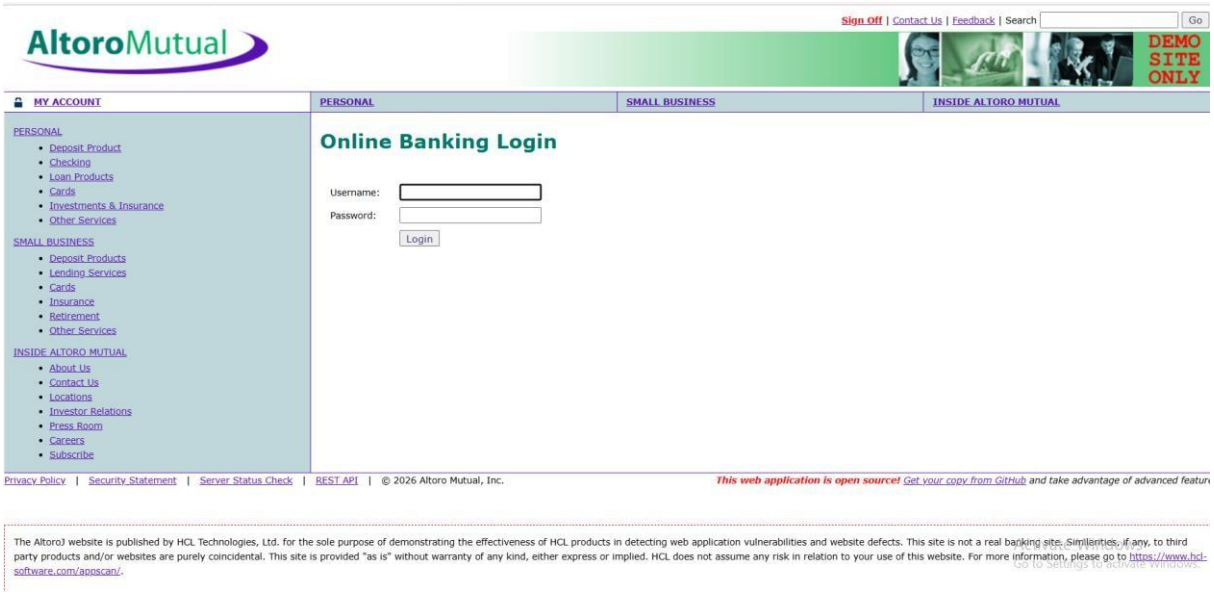
Description:- The product constructs all or part of an SQL command using externallyinfluenced input from an upstream component, but it does not neutralize or incorrectly neutralizes special elements that could modify the intended SQL command when it is sent to a downstream component.

Business Impact::- In summary, it is crucial to underscore that CWE-89, known as SQL Injection, can exert a profound and diverse business impact. This encompasses critical facets such as data breaches, financial setbacks, harm to reputation, legal ramifications, and operational turmoil. Hence, the imperative of preventing and remedying SQL injection vulnerabilities cannot be overstated, as it is indispensable for fortifying the security and continuity of an organization's applications and data.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/login.jsp

Steps to Reproduce: ➢ Access the URL



Also, we will be using burp suite to get requests from the website and know additional information.

With this we can know that sql injection worked and we got the admin privileges. Recommendations: • If parameterized statements are not feasible, use proper input validation and escaping mechanisms to sanitize user inputs before they are used in SQL queries. This helps prevent malicious code injection. • Utilize stored procedures for database operations. This can help separate SQL code from application code and reduce the risk of SQL injection. • Implement strict input validation for all user inputs, ensuring that data adheres to the expected format and structure.

4)

Vulnerability Name:- Broken authentication

CWE/CVE : - 285

Description:- The system's authorization functionality does not prevent one user from gaining access to another user's data or record by modifying the key value identifying the data.

Business Impact::- To effectively mitigate the business impact of CWE-285, it is imperative that organizations place a strong emphasis on bolstering their authentication and session management practices. This should encompass the adoption of multi-factor authentication, the secure storage of credentials, meticulous session handling, and a commitment to conducting routine security assessments and testing. The rectification of these vulnerabilities stands as a critical imperative, safeguarding sensitive data, user identities, and the organization's overarching security stature and reputation.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/login.jsp

Steps to Reproduce: ➢ Access the URL

5)

Vulnerability Name:- Insecure Direct object Reference

CWE/CVE : - 639

OWASP/SANS Category:- A01: Broken Access Control

Description:- Insecure Direct Object Reference (IDOR) is a vulnerability that arises when attackers can access or modify objects by manipulating identifiers used in a web application's URLs or parameters. It occurs due to missing access control checks, which fail to verify whether a user should be allowed to access specific data.

Business Impact::- To effectively mitigate the business impact of CWE-639, organizations must make it a top priority to fortify their access control and authorization mechanisms. This entails the implementation of robust security measures, the regular conduct of comprehensive security assessments, and the deployment of intrusion detection systems to promptly identify and counter unauthorized access attempts. These measures stand as absolutely critical in the defense of sensitive data, the overall security of systems, and the preservation of the organization's esteemed reputation.

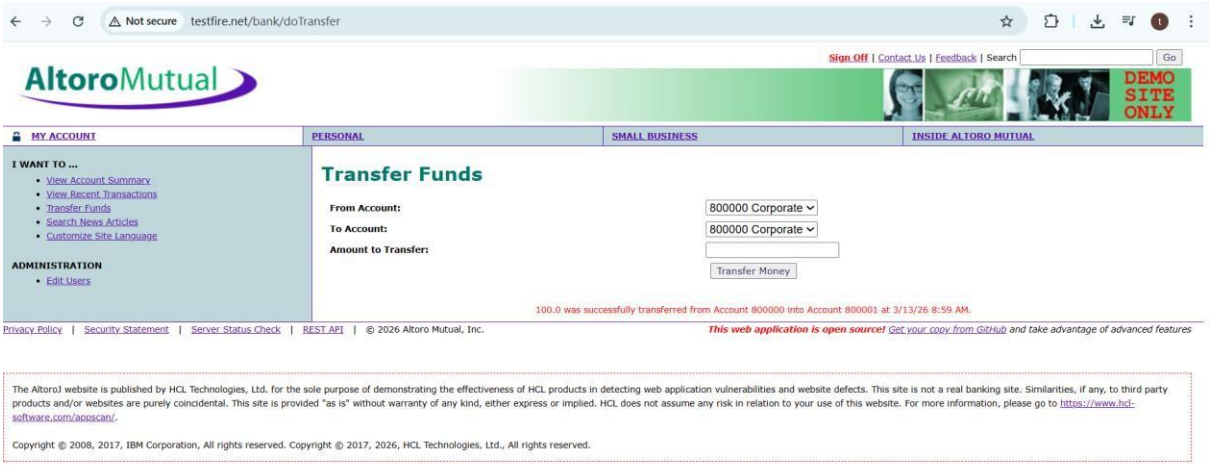
Vulnerability Path: http://testfire.net

Vulnerability Parameter: http://testfire.net/bank/transfer.jsp steps

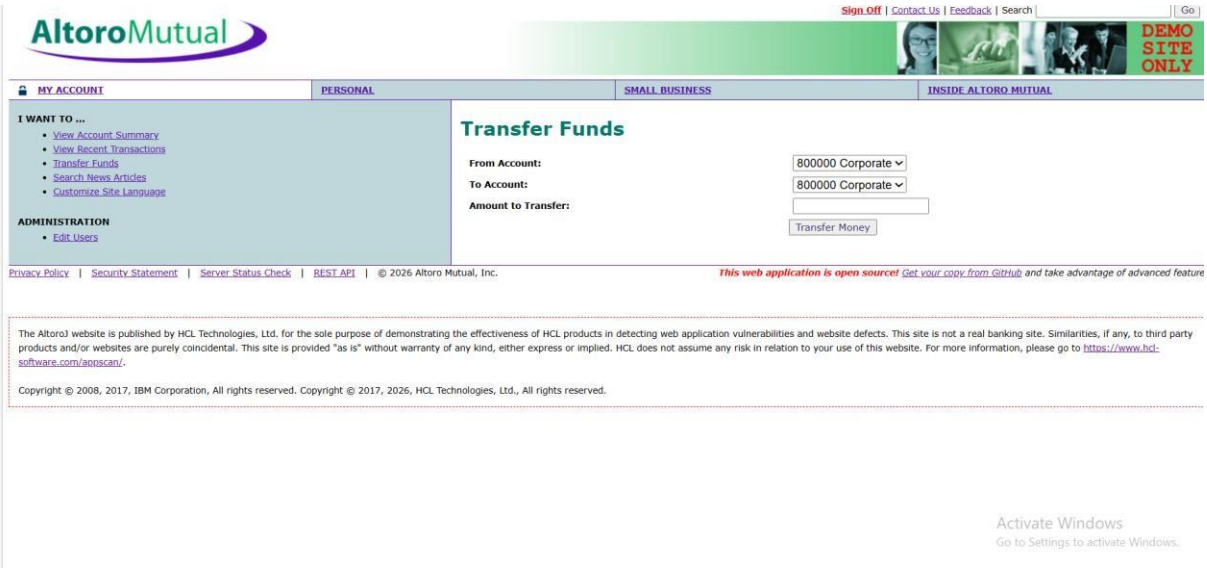
to Reproduce: ➢ Go to the domain. ➢ Sign into the

site

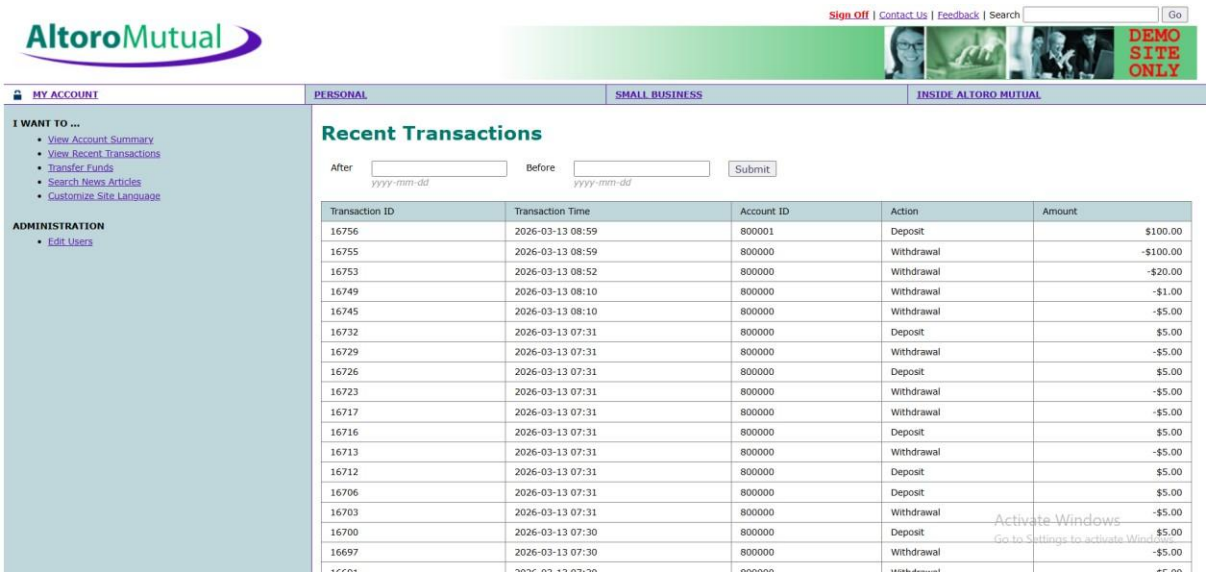
Open “Transfer Money” on the left side and fill in the details. On the intercept and click transfer



Look at the site, we can notice the msg that shows the transfer of 100



Off the Intercept and open “View Recent Transactions”.



Transaction ID	Transaction Time	Account ID	Action	Amount
16756	2026-03-13 08:59	800001	Deposit	$100.00
16755	2026-03-13 08:59	800000	Withdrawal	-$100.00
16753	2026-03-13 08:52	800000	Withdrawal	-$20.00
16749	2026-03-13 08:10	800000	Withdrawal	-$1.00
16745	2026-03-13 08:10	800000	Withdrawal	-$5.00
16732	2026-03-13 07:31	800000	Deposit	$5.00
16729	2026-03-13 07:31	800000	Withdrawal	-$5.00
16726	2026-03-13 07:31	800000	Deposit	$5.00
16723	2026-03-13 07:31	800000	Withdrawal	-$5.00
16717	2026-03-13 07:31	800000	Withdrawal	-$5.00
16716	2026-03-13 07:31	800000	Deposit	$5.00
16713	2026-03-13 07:31	800000	Withdrawal	-$5.00
16712	2026-03-13 07:31	800000	Deposit	$5.00
16706	2026-03-13 07:31	800000	Deposit	$5.00
16703	2026-03-13 07:31	800000	Withdrawal	-$5.00
16700	2026-03-13 07:30	800000	Deposit	$5.00
16697	2026-03-13 07:30	800000	Withdrawal	-$5.00

Recommendation: • Utilize parameterized queries or prepared statements when interacting with databases. This prevents user-controlled input from being executed as SQL code. • Implement a Content Security Policy to mitigate the risk of cross-site scripting (XSS) attacks, which can be used to execute unauthorized queries. • Implement account lockout mechanisms that temporarily suspend accounts after a specified number of unauthorized access attempts to prevent brute force attacks.

6)

Vulnerability Name:- Security Misconfiguration

CWE/CVE : - 723

OWASP/SANS Category**:-**

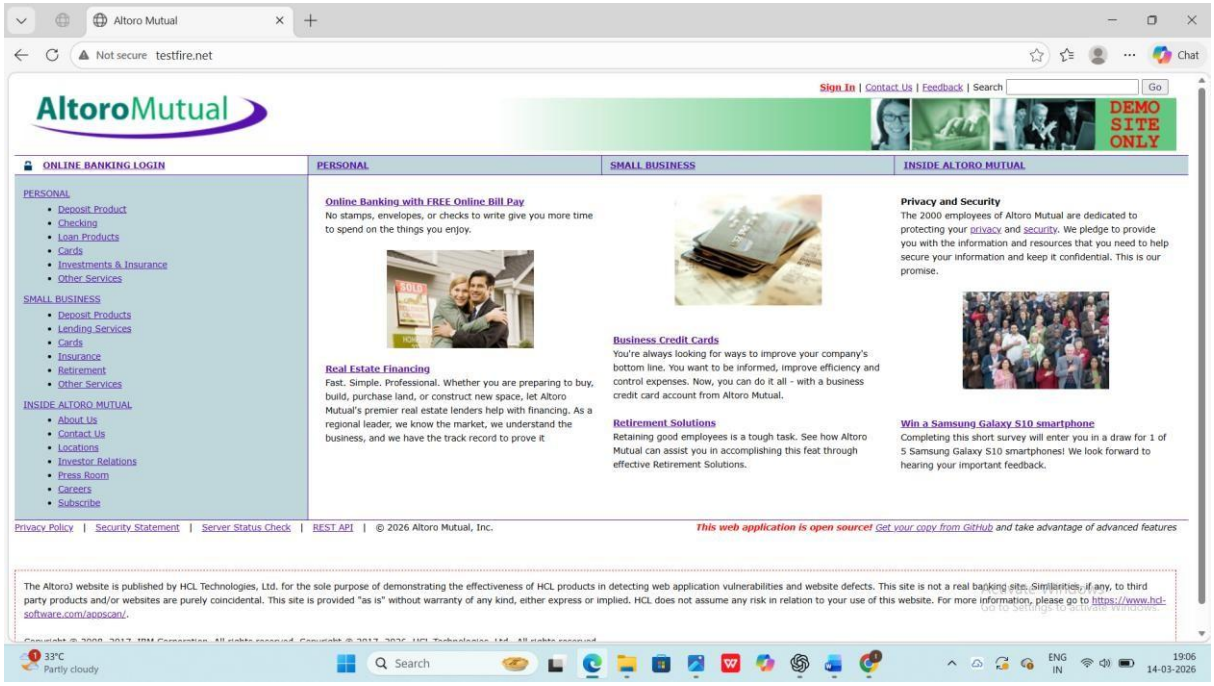
Description:- The product specifies permissions for a security-critical resource in a way that allows that resource to be read or modified by unintended actors**.**

Business Impact::- To effectively lessen the business consequences stemming from CWE-732, organizations must place a strong emphasis on bolstering their configuration management practices. This involves the establishment of secure default settings, the routine conduct of comprehensive security evaluations, and the deployment of intrusion detection systems to promptly detect and address misconfigurations and vulnerabilities. These actions are of paramount importance in safeguarding sensitive data, fortifying system security, and preserving the organization's esteemed reputation.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/login.jsp

Steps to Reproduce: ➢ Access the URL



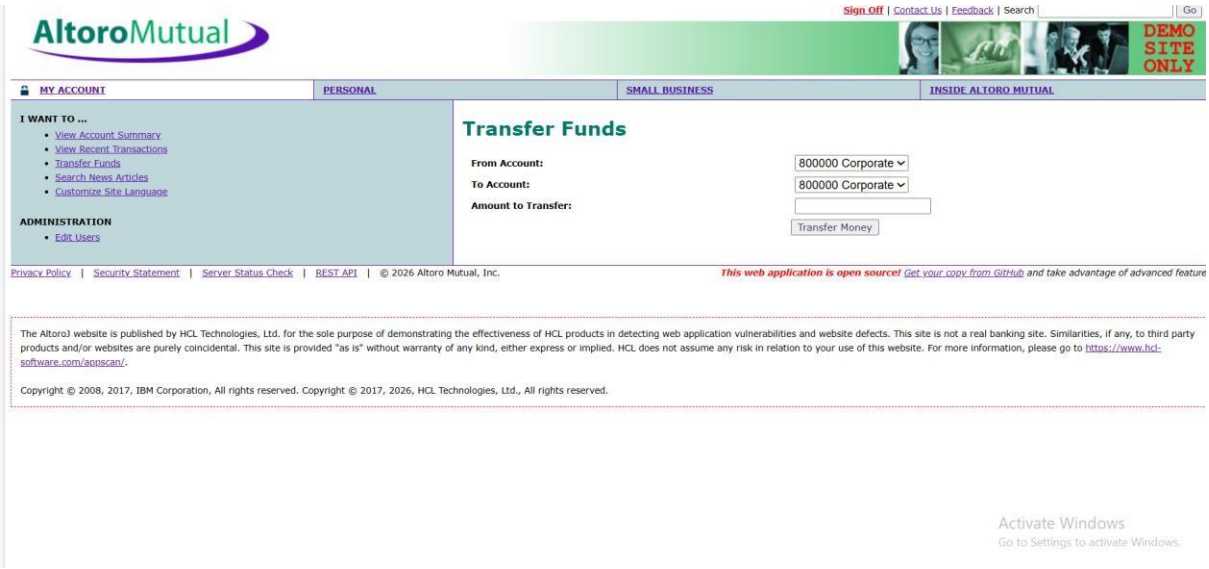
We will be using the uniscan tool which is available in the kali.

```
┌──(kali㉿kali)-[~]
└─$ sudo uniscan -h
[sudo] password for kali:
#######################################
# Uniscan project                     #
# http://uniscan.sourceforge.net/     #
#######################################
V. 6.3

OPTIONS:
        -h      help
        -u      <url> example: https://www.example.com/
        -f      <file> list of url's
        -b      Uniscan go to background
        -q      Enable Directory checks
        -w      Enable File checks
        -e      Enable robots.txt and sitemap.xml check
        -d      Enable Dynamic checks
        -s      Enable Static checks
        -r      Enable Stress checks
        -i      <dork> Bing search
        -o      <dork> Google search
        -g      Web fingerprint
        -j      Server fingerprint

usage:
[1] perl ./uniscan.pl -u http://www.example.com/ -qweds
[2] perl ./uniscan.pl -f sites.txt -bqweds
[3] perl ./uniscan.pl -i uniscan
[4] perl ./uniscan.pl -i "ip:xxx.xxx.xxx.xxx"
[5] perl ./uniscan.pl -o "inurl:test"
[6] perl ./uniscan.pl -u https://www.example.com/ -r
```

Let us go through one webpage to see the vulnerability



Here we can see the sensitive data of job applications which can help an attacker. Recommendations: • Implement a change management process to document and review all changes to system configurations. This helps prevent unauthorized or unintended alterations. • Follow security guidelines provided by software and hardware vendors to ensure secure configurations. • Regularly perform compliance checks against industry standards and regulations to ensure that configurations remain in compliance with security requirements.

7)

Vulnerability Name:- Cross-Site Request Forgery

CWE/CVE : - 352

OWASP/SANS Category:- A08: Cross-Site Request Forgery

Description:- Cross-Site Request Forgery (CSRF) is an attack that forces an end user to execute unwanted actions on a web application in which they're currently authenticated. With a little help of social engineering (such as sending a link via email or chat), an attacker may trick the users of a web application into executing actions of the attacker's choosing. If the victim is a normal user, a successful CSRF attack can force the user to perform state changing requests like transferring funds, changing their email address, and so forth. If the victim is an administrative account, CSRF can compromise the entire web application.

Business Impact::- To effectively reduce the business repercussions of CWE-352, organizations must prioritize secure coding practices, including the incorporation of anti-CSRF tokens, while also conducting routine security assessments and testing to detect and rectify CSRF vulnerabilities. Furthermore, educating users on secure browsing practices is pivotal in preventing CSRF attacks. These actions are of

paramount importance in the protection of data and in upholding the trust of customers and partners.

Vulnerability Path: http://testfire.net/

Vulnerability Parameter: http://testfire.net/bank/transfer.jsp Steps

to Reproduce: ➢ Open https://testfire.net/.

Capture the request in any Intercepting proxy (Burp Suite, Charles Proxy etc.) while transferring the amount from one account to another as shown in the below picture.

Generate CSRF POC using Burp Suite Engagement tools (by modifying the account numbers accordingly)

8)

Vulnerability Name:- Cleartext Transmission of Sensitive Information

CWE/CVE : - 319

OWASP/SANS Category:-

Description:- The product transmits sensitive or security-critical data in cleartext in a communication channel that can be sniffed by unauthorized actors. Many communication channels can be "sniffed" (monitored) by adversaries during data transmission. For example, in networking, packets can traverse many intermediary nodes from the source to the destination, whether across the internet, an internal network, the cloud, etc. Some actors might have privileged access to a network

interface or any link along the channel, such as a router, but they might not be authorized to collect the underlying data. As a result, network traffic could be sniffed by adversaries, spilling security-critical data.

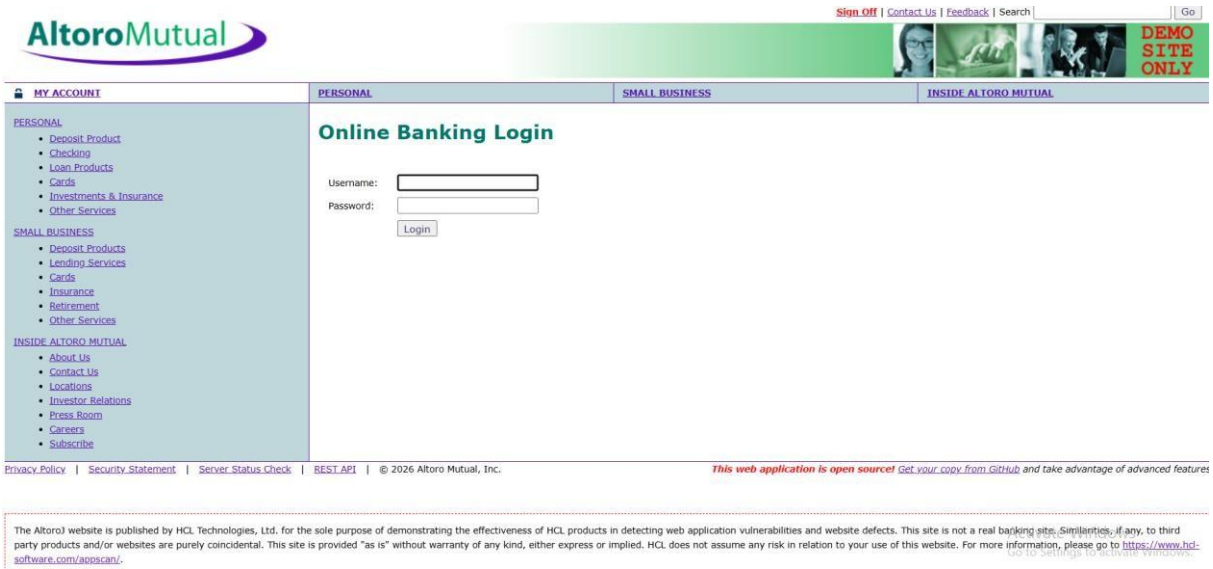
Business Impact::- To effectively reduce the business consequences associated with CWE319, organizations must prioritize the adoption of secure data transmission practices. This includes the utilization of encryption and robust, secure protocols. The routine conduct of security assessments and testing is pivotal in pinpointing and remedying vulnerabilities linked to data transmission. Furthermore, the education of users on secure data handling practices plays a vital role in proactively preventing data exposure incidents. These actions are of paramount importance in the protection of sensitive data and in preserving the trust of both customers and partners.

Vulnerability path: http://testfire.net/

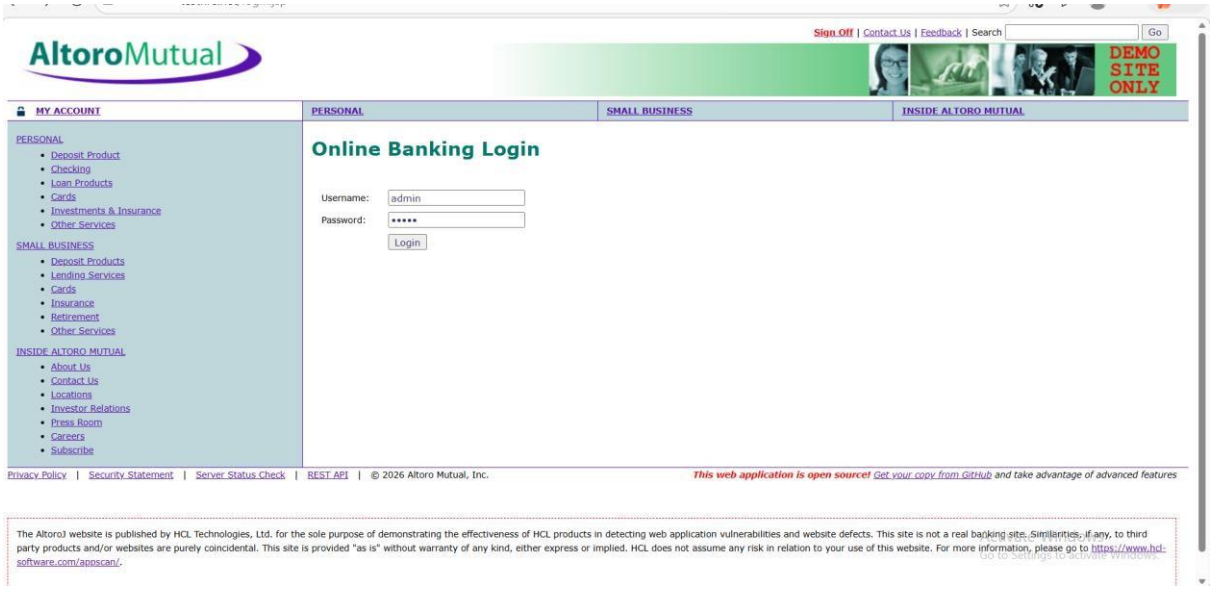
Vulnerability parameter: http://testfire.net/login.jsp

Steps to reproduce: ➢ Access the URL

Now we will try to sign in to this website with admin privileges



Also, we will be using burp suite to get requests from the website and know additional information. ➢ We use ‘admin’ for the username and password.



Recommendations: • Educate users and employees on secure data handling practices, such as recognizing secure websites (look for "https") and avoiding insecure Wi-Fi networks. • Employ data masking or redaction techniques to replace sensitive data with placeholders or cryptographic representations during transmission. • Implement encryption for data in transit. Use secure encryption protocols such as TLS/SSL to protect sensitive information during transmission. • Use secure communication protocols for transmitting data, such as HTTPS for web applications, and ensure that the selected protocols are kept up-to-date.

9)

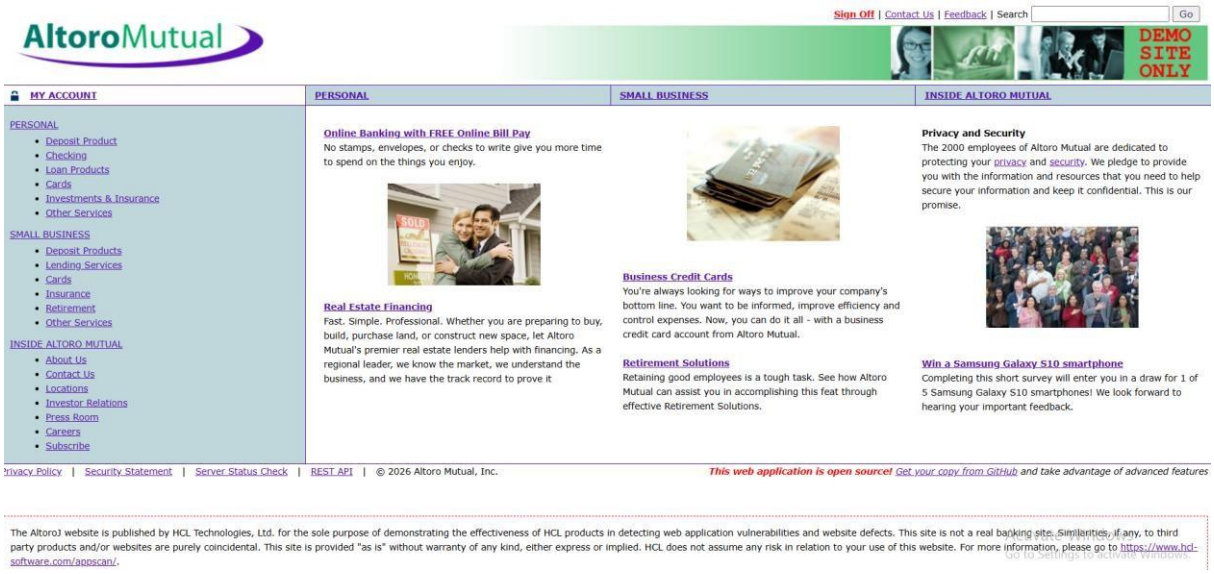
Vulnerability Name:- Click Jacking

CWE/CVE : - 1021

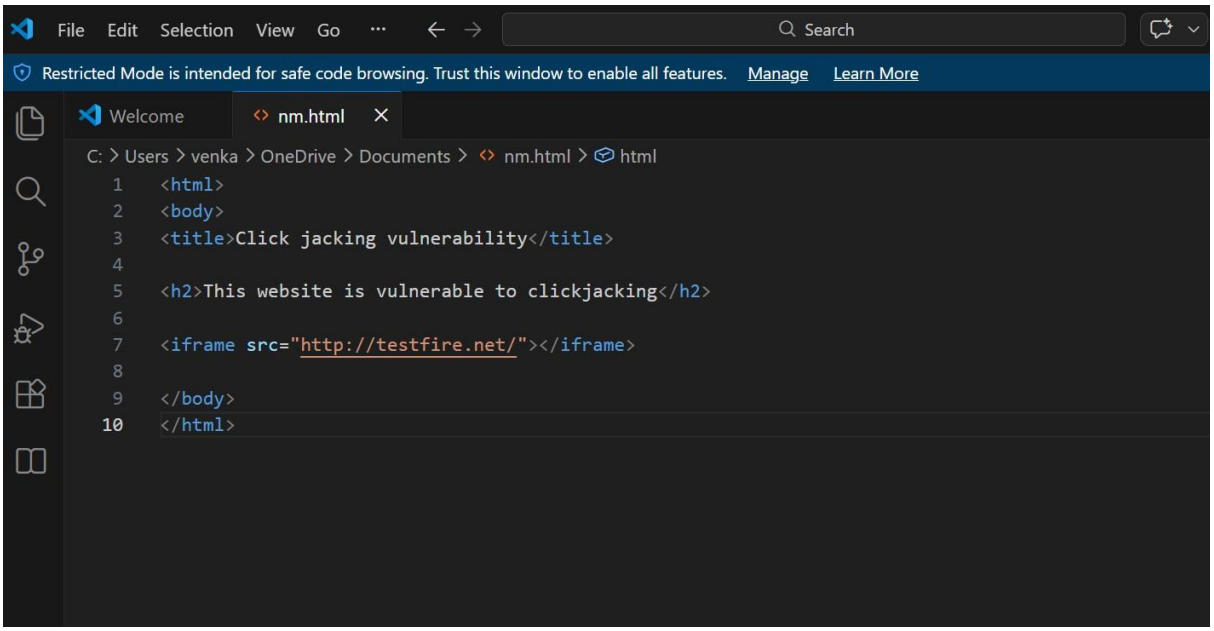
OWASP/SANS Category:-

Description:- The web application does not restrict or incorrectly restricts frame objects or UI layers that belong to another application or domain, which can lead to user confusion about which interface the user is interacting with

Business Impact::- To effectively reduce the business consequences resulting from CWE1021, organizations must prioritize the implementation of protective measures, such as framebusting code. Simultaneously, educating users on safe browsing practices plays a crucial role in preventing clickjacking incidents. Additionally, routine security assessments and testing are pivotal for identifying and mitigating vulnerabilities associated with clickjacking. These actions are of paramount importance in upholding user trust, ensuring data protection, and safeguarding the organization's reputation. Vulnerability path: http://testfire.net/ Vulnerability parameter: http://testfire.net/ Steps to reproduce: ➢ Access the URL



Then take the URL and use it for the html code ➢ we will be writing some html code to perform this vulnerability. we will be writing the code in vs code for better flexibility and functionality.



10)

Vulnerability Name:- web server allows password auto-completion

CWE/CVE : - 310

OWASP/SANS Category:-

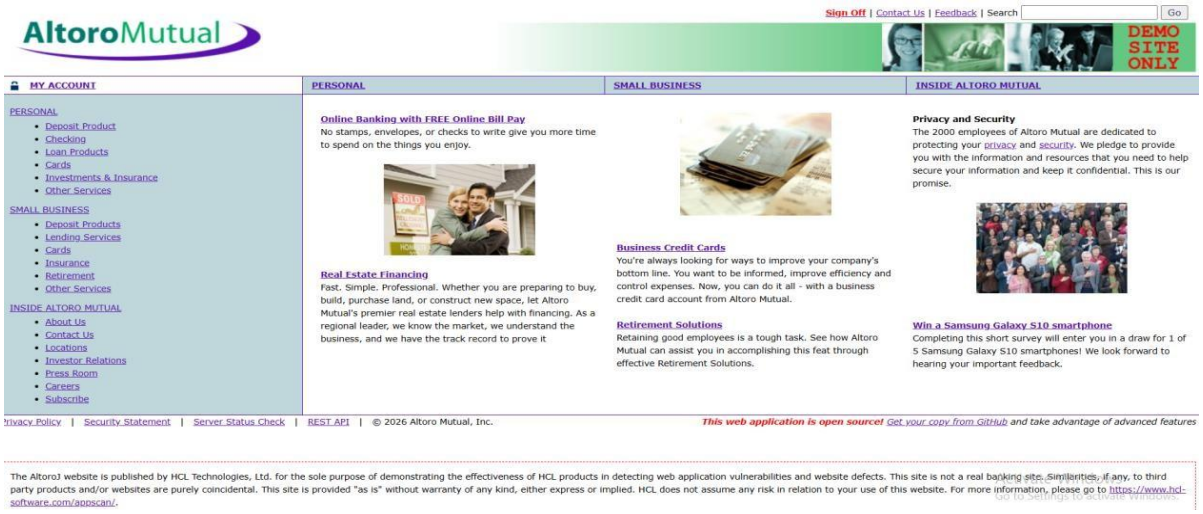
Description:- Weaknesses in this category are related to the design and implementation of data confidentiality and integrity. Frequently these deal with the use of encoding techniques, encryption libraries, and hashing algorithms. The weaknesses in this category could lead to a degradation of the quality data if they are not addressed.

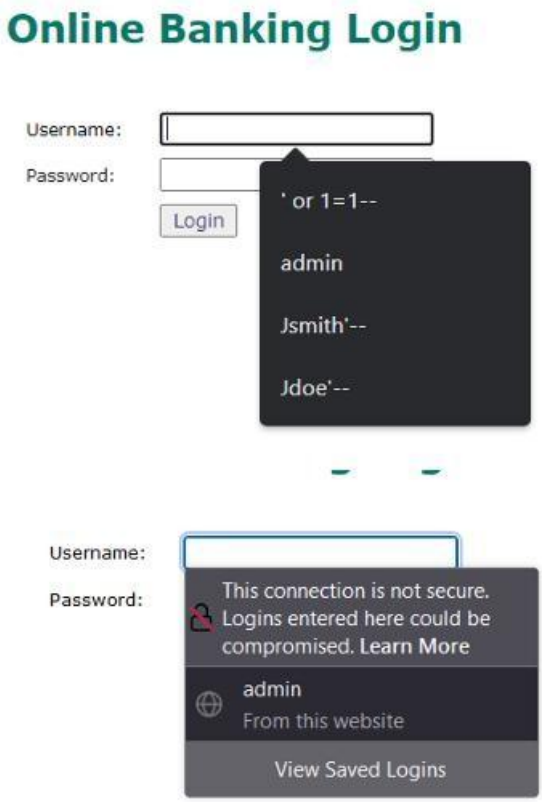
Business Impact::- To effectively lessen the business consequences associated with CWE-310, organizations must prioritize the adoption of secure cryptographic practices. This entails ensuring proper password storage and robust encryption key management. Simultaneously, conducting routine security assessments and testing is pivotal in detecting and mitigating vulnerabilities related to cryptographic issues. Striving for compliance with pertinent data protection regulations and industry standards is equally essential. These actions are of paramount importance in the protection of sensitive data, the upholding of user trust, and the preservation of the organization's esteemed reputation.

Vulnerability path: http://testfire.net/

Vulnerability parameter: http://testfire.net/login.jsp

Steps to reproduce: ➢ Access the URL





➢ From this image we can see the usernames and the passwords getting auto filled. This is a potential vulnerability as this can be a doorway for attackers. Responsibilities: • Implement secure password storage mechanisms, such as using strong and salted cryptographic hashing algorithms like bcrypt or scrypt. • Implement robust encryption key management practices, including secure key storage, key rotation, and access controls. • Utilize well-established and proven cryptographic libraries and algorithms for encryption and decryption. • Use secure encryption protocols, like TLS/SSL, for data transmission over networks to protect data in transit.

Stage – 2

Overview

A typical **Nessus vulnerability scan** includes several important stages that help identify and manage security risks in systems and networks.

1. **Preparation**

Define the Goal:
First, determine the purpose and scope of the scan. Identify which systems or networks will be evaluated and what types of vulnerabilities need to be detected.

Access Authorization:
Ensure you have the required permissions and credentials to scan the selected systems or network resources.

2. **Configuration**

Create Scan Policy:
Configure a scan policy that sets the scanning parameters. This includes defining the vulnerability checks, scan schedule, and other specific settings.

Specify Targets:
Identify the systems to be scanned by entering their IP addresses, hostnames, or network ranges.

3. **Scanning**

Start the Scan:
Launch the Nessus scan using the configured policy and defined targets. Nessus will analyze the systems step-by-step using its vulnerability detection plugins.

4. **Vulnerability Detection**

During the scan, Nessus evaluates the systems to identify security weaknesses such as vulnerabilities, incorrect configurations, open ports, and other potential threats. The discovered issues are categorized based on severity levels, helping security teams prioritize which issues need immediate attention.

5. **Reporting**

After the scan is completed, Nessus generates comprehensive reports that list all identified vulnerabilities. These reports contain details such as severity ratings, suggested remediation steps, and evidence supporting the findings. Reports can be exported in formats like **PDF, HTML, or CSV** for documentation and analysis.

6. **Remediation**

Analyze Results:
Security and IT teams review the scan reports to understand and prioritize the vulnerabilities.

Apply Fixes:
Necessary corrective measures are then implemented, such as installing patches, updating configurations, or applying additional security controls.

7. **Follow-Up**

Routine Scanning:
Regular scans should be conducted to continuously monitor system security. This allows organizations to detect new vulnerabilities and verify whether previously identified issues have been resolved.

Integration:
Nessus can also be connected with other security tools or management systems to automate vulnerability tracking and response processes.

8. **Compliance Verification (If Required)**

If the scan includes compliance checks, the results should be reviewed to confirm that systems meet required industry standards and regulatory guidelines.

9. **Documentation**

All scan reports, remediation activities, and compliance assessments should be properly documented for auditing and future reference.

10. **User Training**

IT and security personnel should receive adequate training to effectively operate Nessus and accurately interpret scan results.

Nessus scanning plays a vital role in **proactive cybersecurity** by helping organizations detect and resolve vulnerabilities in their IT infrastructure. The frequency and depth of scans may differ depending on an organization's security policies and operational requirements.

Understanding Nessus Scans

Nessus is a widely used **vulnerability scanning tool** designed to identify security weaknesses in computer systems and networks. Security professionals rely on it to evaluate the security condition of their infrastructure and detect vulnerabilities before attackers can exploit them.

Key Features of Nessus

1. **Vulnerability Detection**
   Nessus performs security assessments by scanning systems or networks to detect issues such as outdated software, missing security patches, misconfigurations, weak authentication settings, and other potential threats.

2. **Network Analysis**

The tool can scan multiple types of network devices including servers, routers, switches, and firewalls. It examines open ports, running services, and installed software.

3. **Plugin-Based System**
   Nessus operates using a plugin architecture. These plugins allow it to detect a wide range of vulnerabilities and are frequently updated to include the latest security checks.

4. **Compliance Assessment**
   Nessus can evaluate systems against various regulatory and security standards, such as **PCI DSS** or **CIS benchmarks**, helping organizations maintain compliance.

5. **Flexible Configuration**
   Users can tailor scans according to organizational requirements by defining scan policies, choosing target systems, and selecting specific vulnerability checks.

6. **Detailed Reporting**
   The tool produces comprehensive reports showing detected vulnerabilities, their risk levels, and recommended remediation steps. These reports help IT teams prioritize security improvements.

7. **Regular Security Monitoring**
   Many organizations schedule Nessus scans regularly to maintain continuous visibility into their security posture and to quickly identify newly emerging threats.

8. **Tool Integration**
   Nessus can integrate with other security platforms, enabling automated scanning and more efficient vulnerability management.

9. **Licensing Options**
   Nessus is available in both **free and paid versions**. The free version provides limited features, while the commercial edition offers advanced capabilities and support.

10. **User-Friendly Interface**
    Nessus includes an intuitive web-based interface, making it convenient for both experienced security analysts and less experienced IT staff to perform scans and review results.

It's important to note that Nessus is a valuable tool for identifying vulnerabilities, but it doesn't fix these vulnerabilities itself. It's up to the organization's IT and security teams to take the necessary steps to remediate the identified issues to enhance their security.

List of vulnerability

S. No	Vulnerability Name	Severity	Plugins ID
1	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	Low	3875
2	Nessus SYN scanner	Info	11219
3	Additional DNS Hostnames	Info	46180
4	Open Port Re-check	Info	10919
5	TLS Version 1.0 Protocol Detection	Medium	104743

Target Website: testfire.net

Target IP Address:65.61.137.117

Report

1)

VULNERABILITY NAME: SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

SEVERITY: Low

PLUGIN: 3875

PORT: N/A

DESCRIPTION: The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

SOLUTION: Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact::- The use of weak Diffie-Hellman keys (≤1024 bits) in SSL/TLS can make encrypted communications vulnerable to cryptographic attacks. An attacker may be able to decrypt sensitive data or manipulate the connection, which could compromise data confidentiality and integrity. Although the severity is low, it may still expose business information if exploited.

2)

Vulnerability Name:- Nessus SYN scanner

severity : - Info

Plugin:- 11219

Port :-N/A

Description:- : This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded.

solution:- Protect your target with an IP filter.

Business Impact::- The SYN scanner reveals open ports and services running on the target system. Attackers could use this information to identify potential entry points and plan further attacks on vulnerable services. Although the severity is informational, exposed port details may increase the risk of targeted network attacks if proper filtering is not implemented.

3)

Vulnerability Name:- Additional DNS Hostnames

severity : -Info

Plugin:- 46180

Port :-N/A

Description:- Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the

remote host. Note that these are only the alternate hostnames for vhosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

solution:- If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com[192.0.32.10]

Business Impact::- The discovery of additional DNS hostnames may reveal alternate domains or virtual hosts associated with the same server. Attackers could use this information to identify hidden web services or applications that may contain vulnerabilities. While the severity is informational, exposed hostnames can help attackers gather intelligence about the network structure.

4)

Vulnerability Name:- Open Port Re-

check **severity : -**Info **Plugin:-** 10919

Port :- 8443

Description:- One of several ports that were previously open are now closed or unresponsive.

There are several possible reasons for this :

- The scan may have caused a service to freeze or stop running.

- An administrator may have stopped a particular service during the scanning process.

This might be an availability problem related to the following :

- A network outage has been experienced during the scan, and the remote network cannot be reached anymore by the scanner.

- This scanner may has been blacklisted by the system administrator or by an automatic intrusion detection / prevention system that detected the scan.

- The remote host is now down, either because a user turned it off during the scan or because a select denial of service was effective.

In any case, the audit of the remote host might be incomplete and may need to be done again.

Solution:- Steps to resolve this issue include :

- Increase checks_read_timeout and/or reduce max_checks.

- Disable any IPS during the Nessus scan

Business Impact::- If previously open ports become closed or unresponsive during the scan, it may indicate service interruptions, network issues, or security controls blocking the scan. This can result in incomplete vulnerability assessments and may hide potential security risks. It may also suggest possible service instability or availability issues within the system.

5)

Vulnerability Name:- TLS Version 1.0 Protocol Detection
severity : - Medium

Plugin:- 104743

Port :- 443 / tcp / www

Description:- The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors.

PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits.

Solution:- Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact::- The use of TLS 1.0 exposes the system to known cryptographic weaknesses, which may allow attackers to intercept or manipulate sensitive data transmitted over the network. It may also lead to compliance issues with security standards such as PCI DSS and cause compatibility problems with modern browsers and services that no longer support TLS 1.0.

S. No	Vulnerability Name	Severity	Plugins ID
1	SSL Root Certification Authority Certificate Information	Info	94761
2	HyperText Transfer Protocol (HTTP) Information	Info	24260
3	OS Identification	Info	11936
4	SSL Certificate Signed Using Weak Hashing Algorithm (Known CA)	Info	95631
5	Additional DNS Hostnames	Info	46180

Target Website: vit.ac.in

Target IP Address: 122.184.65.22

REPORT:-

1)

Vulnerability Name:- SSL Root Certification Authority Certificate Information
severity : - Info

Plugin:- 94761

Port :- 443 / tcp / www

Description:- The remote service uses an SSL certificate chain that contains a self-signed root Certification Authority certificate at the top of the chain.

solution:- Ensure that use of this root Certification Authority certificate complies with your organization's acceptable use and security policies.

Business Impact::- The presence of a self-signed root Certification Authority certificate may reduce the trust level of the SSL/TLS connection. If not properly managed, it could lead to trust issues or make the system vulnerable to spoofing or man-in-the-middle attacks. Although informational, improper certificate management may affect secure communications.

2)

Vulnerability Name:- HyperText Transfer Protocol (HTTP) Information

severity : - Info

Plugin ID:- 24260

Port :- 80 / tcp / www

Description:- The remote host is running an HTTP server that supports HTTP/2 running over cleartext TCP (h2c).

solution:- Limit incoming traffic to this port if desired.

Business Impact::- The HTTP service running over cleartext TCP may expose web traffic to interception or monitoring by attackers. Sensitive data transmitted without encryption could be viewed or modified. Even though the severity is informational, unsecured HTTP communication may increase the risk of data exposure.

3)

Vulnerability Name:- OS

Identification

severity : -Info Plugin:- 11936 Port **:-**

N/A

Description:- Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP,
SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Business Impact::- Operating system identification can reveal information about the system's platform and version. Attackers may use this information to target specific vulnerabilities related to that operating system. Although the severity is informational, it may assist attackers in planning targeted attacks against the system.

4)

Vulnerability Name:- SSL Certificate Signed Using Weak Hashing Algorithm (Known CA)

severity : -Info

Plugin:- 95631

Port :- 443 / tcp / www

Description:- The remote service uses a known CA certificate in the SSL certificate chain that has been signed using a cryptographically weak hashing algorithm (e.g., MD2, MD4, MD5, or SHA1). These signature algorithms are known to be vulnerable to collision attacks (CVE-2004-2761, for example). An attacker can exploit this to generate another certificate with the same digital signature, allowing the attacker to masquerade as the affected service.

Note that this plugin reports all SSL certificate chains signed with SHA-1 that expire after January 1, 2017 as vulnerable. This is in accordance with Google's gradual sunsetting of the SHA-1 cryptographic hash algorithm.

Note that this plugin will only fire on root certificates that are known certificate authorities as listed in Tenable Community Knowledge Article 000001752. That is what differentiates this plugin from plugin 35291, which will fire on any certificate, not just known certificate authority root certificates.

Known certificate authority root certificates are inherently trusted and so any potential issues with the signature, including it being signed using a weak hashing algorithm, are not considered security issues.

solution:- Contact the Certificate Authority to have the certificate reissued.

Business Impact::- Using an SSL certificate signed with a weak hashing algorithm (such as SHA-1 or MD5) may reduce the strength of the certificate’s security. Attackers could potentially exploit hash collisions to create a fraudulent certificate and impersonate the service. Although informational, it may affect the trust and integrity of secure communications.

5)

Vulnerability Name:- Additional DNS Hostnames

severity :-Info

Plugin:- 46180

Port :- N/A

Description:- Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for vhosts discovered on a web server.

Different web servers may be hosted on name-based virtual hosts.

solution:- If you want to test them, re-scan using the special vhost syntax, such as :

www.example.com[192.0.32.10]

Business Impact::- The presence of additional DNS hostnames may expose alternate domains or virtual hosts linked to the same server. Attackers could use this information to discover hidden websites or services that might contain security weaknesses. Although the severity is informational, it may assist attackers in gathering reconnaissance about the system.

Stage 3

Title:

Design and Implementation of Context-Aware Access Control Based on User Identity

The implementation of context-aware access control based on user identity represents a significant transition from traditional network-centric security models to a more advanced and resilient identity-centric Zero Trust architecture. In conventional security approaches, access to applications and network resources is typically granted based on network location or perimeter-based defenses, which often leaves organizations vulnerable to unauthorized access, lateral movement, and various network-based cyber threats.

In contrast, context-aware access control focuses on verifying the identity of the user along with multiple contextual parameters such as device posture, geographic location, time of access, authentication strength, and behavioral patterns before granting access to critical resources. By leveraging technologies such as Zscaler Private Access (ZPA) and integrating identity providers, organizations can ensure that users are authenticated and authorized dynamically, allowing access only to the specific applications they are permitted to use.

This approach follows the Zero Trust principle of “never trust, always verify,” ensuring that every access request is continuously validated regardless of where the user is located. Additionally, enforcing least-privilege access policies ensures that users receive only the minimum level of access required to perform their tasks, significantly reducing the attack surface and preventing potential misuse of privileges.

The implementation also makes private applications invisible to the public internet, thereby protecting them from external attacks such as scanning, exploitation, and unauthorized probing.
Furthermore, this identity-driven security model enhances visibility and monitoring capabilities by providing detailed logs and analytics of user activities and application

interactions, which can be utilized by Security Operations Centers (SOC) for threat detection, incident response, and security analysis.

It also simplifies IT operations by reducing reliance on legacy VPN infrastructure and enabling secure, scalable access for a distributed workforce, including remote employees, third-party vendors, and cloud-based workloads. Ultimately, the deployment of context-aware access control based on user identity establishes a strong and future-ready cybersecurity framework that not only strengthens organizational security posture but also supports secure digital transformation, improved compliance, and efficient management of access to sensitive applications and network resources.

Conclusion

Stage 1:

Web Application Testing

In conclusion, web application testing plays a vital role in ensuring the reliability, security, and overall performance of web-based systems. It involves systematically evaluating different components of a web application such as the user interface, functionality, compatibility, performance, and security to detect and resolve potential issues before deployment. By identifying vulnerabilities and errors during the testing phase, organizations can significantly improve the quality and stability of their applications while reducing the risk of failures or cyber threats. As web applications continue to become an essential part of business operations and daily digital activities, effective testing practices are necessary to guarantee a smooth, efficient, and secure user experience. Therefore, web application testing not only enhances software quality but also helps organizations maintain trust, reliability, and strong cybersecurity protection.

Stage 2:

Conclusion – Vulnerability Assessment Using Nessus

In conclusion, the vulnerability assessment performed using the Nessus scanner provided valuable insights into the security status of the selected web application. The

scan identified several potential vulnerabilities and categorized them based on their severity levels, allowing security teams to prioritize critical and high-risk issues that require immediate attention. The generated report offered detailed recommendations such as applying security patches, updating configurations, and implementing appropriate security controls to mitigate identified risks. Additionally, the assessment emphasized the importance of following established cybersecurity standards and best practices, including guidelines provided by OWASP, to ensure better protection against common web application threats. Overall, the Nessus vulnerability assessment highlights the need for continuous monitoring, regular security updates, and proactive risk management to maintain a strong and resilient cybersecurity posture.

Stage 3:

Conclusion – Context-Aware Access Control Based on User Identity

In conclusion, the design and implementation of context-aware access controls based on user identity represents a significant step toward modern cybersecurity practices aligned with the Zero Trust security model. Unlike traditional security approaches that rely primarily on network-based trust, this method verifies user identity along with contextual factors such as device compliance, location, authentication strength, and user behavior before granting access to applications or resources. By enforcing least-privilege access policies, organizations can ensure that users are granted only the minimum permissions necessary to perform their tasks, thereby reducing the risk of unauthorized access and potential cyber attacks. Furthermore, identity-driven access control improves security visibility and monitoring capabilities, enabling organizations to track user activities and detect anomalies more effectively. This approach also supports secure remote access for distributed users and minimizes reliance on traditional VPN infrastructure. Ultimately, implementing context-aware access controls strengthens organizational security, enhances operational efficiency, and provides a scalable foundation for protecting critical digital resources in the evolving cybersecurity landscape.

Future Scope

Stage 1:

Future Scope of Context-Aware Access Control Based on User Identity

The future scope of designing and applying context-aware access controls based on user identity is rapidly expanding as organizations move toward modern cybersecurity

frameworks such as Zero Trust. As digital systems, cloud services, and remote work environments continue to grow, identity-based access control will play a critical role in protecting sensitive data and applications. By evaluating contextual factors such as user identity, device security status, location, and behavior, organizations can make smarter and more secure access decisions.

One key future development is the **integration of Artificial Intelligence (AI) and Machine Learning (ML)** to automatically analyze user behavior and detect unusual access patterns. These technologies can help identify potential security threats in real time and strengthen access control mechanisms.

Another important area is **enhanced device and endpoint verification**, where systems will continuously check device health, security patches, and compliance status before granting access to resources.

The **growth of cloud computing and remote work environments** will also increase the importance of identity-based access systems, ensuring secure access to applications regardless of user location.

Additionally, **multi-factor authentication (MFA) and adaptive authentication** will become more widely adopted to provide stronger identity verification.

Overall, the future of context-aware access control lies in creating more intelligent, automated, and adaptive security systems that can effectively protect organizational resources while maintaining a seamless user experience.

Stage 2:

Future Scope of the Testing Process

The future scope of the web application testing process, especially in the area of vulnerability identification, is highly promising due to the rapid expansion of digital platforms, the increasing need for strong cybersecurity, and the continuously evolving threat environment. As web technologies grow more complex, testing methodologies must also advance to effectively detect and mitigate potential security weaknesses. The role of testers will become more important in ensuring that applications remain secure, reliable, and resistant to modern cyber threats.

One of the major developments in this field will be the **use of Artificial Intelligence (AI) and Machine Learning (ML) in testing tools**. These advanced technologies will help automate vulnerability detection by analyzing large volumes of code and system behavior quickly and accurately. AI-driven testing tools can identify patterns and hidden security flaws that may be difficult for manual testing processes to detect.

Another growing area is **testing for IoT devices and mobile applications**. With the rapid adoption of Internet of Things devices and the widespread use of mobile platforms, web applications increasingly interact with various connected systems. Ensuring the security of these devices, their communication interfaces, and the applications that control them will become an essential part of the testing process.

In addition, **security testing for blockchain-based systems and cryptocurrency platforms** will gain importance as these technologies become more widely used for financial transactions and digital asset management. Testing will focus on ensuring the integrity, reliability, and security of blockchain applications to prevent fraud and unauthorized access.

The rise of **serverless computing architectures** will also influence future testing practices. As organizations adopt serverless platforms, testers will need to evaluate the security of serverless functions, APIs, and cloud-based services to ensure that these components are properly configured and protected from vulnerabilities.

Furthermore, the increasing use of **containerization technologies such as Docker and Kubernetes** will expand the scope of security testing. Testers will need to assess container images, configurations, and orchestration environments to ensure that they are secure and free from potential weaknesses that attackers could exploit.

Overall, the future of web application testing will involve more advanced tools, automation, and specialized security testing techniques to address the growing complexity of modern digital systems and protect them from emerging cybersecurity threats.

Stage 3:

Future Scope of Context-Aware Access Control

The successful implementation of identity-based and context-aware access control systems establishes a strong foundation for building a more advanced and integrated cybersecurity environment. As organizations continue to adopt cloud technologies, remote work models, and digital services, further improvements can be made to strengthen security and improve access management. Future developments will focus on integrating advanced technologies, improving monitoring capabilities, and enhancing automated security responses.

One important future direction is the **integration of different secure access platforms** to create a unified security architecture. Combining private application access solutions with secure internet access platforms can form a comprehensive

Secure Access Service Edge (SASE) framework, enabling organizations to manage both internal and external traffic using a single centralized policy system.

Another area of development is **advanced device posture verification**, where access decisions are not only based on user identity but also on the real-time security status of the user's device. Integration with endpoint detection and response (EDR) systems can help identify compromised devices and automatically block access to critical resources.

The implementation of **privileged remote access for third-party vendors and contractors** is also expected to expand. Organizations can provide controlled and time-limited access to critical systems with proper auditing and monitoring, reducing reliance on traditional access methods such as jump servers or bastion hosts.

Future improvements may also involve **segmentation of IoT and operational technology (OT) devices**, ensuring that these devices communicate only with authorized management systems. This approach reduces the risk of unauthorized access and limits potential attack surfaces within connected environments.

Additionally, **AI-based anomaly detection systems** can be used to analyze access logs and user behavior patterns. Machine learning algorithms can identify unusual activities, such as login attempts from unfamiliar locations or abnormal access times, and trigger security actions like multi-factor authentication challenges or temporary access restrictions.

Another important development is **cloud workload protection**, where identity-based access control can secure communication between cloud applications, containers, and microservices across multi-cloud platforms. This ensures that internal traffic between workloads remains encrypted and authenticated.

Furthermore, **automated access provisioning and deprovisioning** will play a major role in future security systems. Integration with identity management platforms can automatically grant or revoke access when an employee joins, changes roles, or leaves the organization, ensuring accurate and timely access control.

Finally, organizations may implement **digital experience monitoring tools** to continuously evaluate user access performance. These tools can detect issues such as network delays, connectivity problems, or application performance degradation, allowing IT teams to resolve problems before they affect user productivity.

Overall, the future of context-aware access control lies in creating intelligent, automated, and integrated security systems that provide strong protection for digital resources while maintaining efficient and seamless user access.

Topics Explored

1. **Zscaler** – Studied the cloud-based security platform used to provide secure access to applications and protect organizational networks.
2. **Zero Trust Security Model** – Understood the concept of “never trust, always verify,” where every user and device must be authenticated before accessing resources.
3. **Zscaler Private Access (ZPA)** – Learned how ZPA provides secure access to private applications without exposing them to the public internet.
4. **Virtual Private Network (VPN)** – Explored traditional remote access technology used to securely connect users to internal networks.
5. **MISP (Malware Information Sharing Platform)** – Examined the platform used for sharing threat intelligence and cybersecurity information among organizations.
6. **College Network Information** – Analyzed the structure and components of the college network infrastructure for security evaluation.
7. **Deployment of SOC in the College** – Studied the concept and process of establishing a Security Operations Center (SOC) to monitor and manage security incidents.
8. **Threat Intelligence** – Learned how organizations collect and analyze information about potential cyber threats to improve security defenses.
9. **Incident Response** – Explored the procedures and strategies used to detect, respond to, and recover from cybersecurity incidents.

Tools Explored

▪ **Nessus Scanner** – Used for vulnerability assessment to identify security weaknesses in web applications and network systems, helping organizations take corrective actions to strengthen their cybersecurity posture.